

SPRINT 4 – ESTUDO DE CASO

Estudo de Caso: Auditoria de Sistemas em uma Empresa de Comércio Eletrônico

Contexto

Uma empresa de comércio eletrônico observou um aumento no número de reclamações relacionadas a acessos indevidos às contas de clientes. Diante dessa situação, a organização decidiu realizar uma auditoria de sistemas para avaliar seus controles de segurança.

Escopo

Foram analisados os seguintes elementos:

- Sistema de autenticação de usuários;
- Controle de acessos;
- Banco de dados de clientes;
- Procedimentos de backup;
- Políticas de segurança da informação.

Objetivo

Identificar possíveis vulnerabilidades nos sistemas da organização e verificar se os controles existentes eram suficientes para proteger os dados dos clientes.

Metodologia Utilizada

Planejamento

Definição dos sistemas, processos e recursos que seriam avaliados durante a auditoria.

Coleta de Evidências

Análise de registros de acesso, documentação dos sistemas e configurações de segurança.

Avaliação dos Controles

Verificação dos mecanismos de autenticação, permissões de acesso e procedimentos de proteção dos dados.

Elaboração do Relatório

Registro das vulnerabilidades encontradas e das recomendações de melhoria.

Conclusões

A auditoria identificou alguns pontos que precisavam de melhorias:

- Políticas de senha pouco rigorosas;
- Ausência de autenticação multifator;
- Falhas no monitoramento de acessos suspeitos;
- Testes de recuperação de backup não realizados periodicamente.

Com base nos resultados obtidos, foram recomendadas ações corretivas para fortalecer a segurança dos sistemas e reduzir os riscos relacionados ao acesso indevido às informações.

Referências

- ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. ISACA, 2019.
- ISO/IEC 27001. *Information Security Management Systems*. ISO, 2022.
- TRIBUNAL DE CONTAS DA UNIÃO. *Manual de Auditoria de Tecnologia da Informação*. Brasília: TCU.